

MATRIX MINDS

Ethical Hacking

Legal, hands-on offensive security from a home lab to a professional report.

Drafted by S. Hareedh

Founder, Matrix Minds

© 2026 Matrix Minds. All rights reserved.

Table of Contents

1	Chapter 1 — What Ethical Hacking Means
2	Chapter 2 — Setting Up a Safe Lab
3	Chapter 3 — The Five Phases of a Pentest
4	Chapter 4 — Networking Fundamentals for Hackers
5	Chapter 5 — Web Application Hacking (OWASP Top 10)
6	Chapter 6 — Password Attacks and Authentication
7	Chapter 7 — Wireless and Social Engineering
8	Chapter 8 — Reporting, Career, and Responsible Disclosure

Chapter 1 — What Ethical Hacking Means

Ethical hacking — also called penetration testing or offensive security — is the authorised practice of probing systems for weaknesses so they can be fixed before criminals exploit them. The word 'authorised' is the entire ethical foundation. Without written permission, the same actions are crimes under laws like the IT Act 2000 (India), the Computer Fraud and Abuse Act (US), and the Computer Misuse Act (UK).

The hacker mindset

Curiosity, persistence, and a refusal to accept 'it should not be possible' without proof.

Chapter 2 — Setting Up a Safe Lab

Never practise on systems you do not own or have explicit written permission to test. Build a home lab using VirtualBox or VMware with: Kali Linux (attacker), Metasploitable 2/3 and OWASP Juice Shop (vulnerable targets), and an isolated host-only network so nothing escapes.

Legal vulnerable targets to practise on

HackTheBox, TryHackMe, PortSwigger Web Security Academy, OverTheWire, PicoCTF, VulnHub. All are designed for legal practice.

Chapter 3 — The Five Phases of a Pentest

1. Reconnaissance

Passive (Google dorking, WHOIS, Shodan, LinkedIn) and active (DNS enumeration, subdomain discovery with amass/subfinder). Goal: understand the attack surface.

2. Scanning

nmap for port and service discovery; nuclei and nikto for known-vulnerability templates.

3. Gaining Access

Exploit a discovered weakness — weak credentials, an unpatched CVE, a web vulnerability.

4. Maintaining Access

In an authorised engagement, demonstrate persistence (a reverse shell, scheduled task) so the client understands the impact.

5. Reporting

The deliverable. A clear, reproducible report with severity, evidence, business impact, and remediation steps is what clients actually pay for.

Chapter 4 — Networking Fundamentals for Hackers

You cannot attack what you do not understand. Master: the OSI and TCP/IP models, the three-way handshake, common ports (22 SSH, 80 HTTP, 443 HTTPS, 445 SMB, 3389 RDP), subnetting, NAT, DNS resolution, and how TLS works.

Tools

Wireshark for packet analysis, tcpdump for the terminal, netcat as the Swiss army knife of TCP.

Chapter 5 — Web Application Hacking (OWASP Top 10)

Injection (SQLi, command injection)

Untrusted input concatenated into a query or shell command. Defence: parameterised queries, never `shell=True` with user input.

Broken Access Control

Most common modern bug. Defence: enforce authorisation server-side on every endpoint; never trust the client.

Cross-Site Scripting (XSS)

Reflected, stored, and DOM-based. Defence: contextual output encoding and a strict Content Security Policy.

Cross-Site Request Forgery (CSRF)

Defence: SameSite cookies and anti-CSRF tokens on state-changing requests.

Server-Side Request Forgery (SSRF)

The server fetches an attacker-controlled URL — often internal cloud metadata. Defence: allow-list outbound destinations.

Insecure Deserialisation, Vulnerable Components, Logging Failures

Patch dependencies, log security-relevant events centrally, alert on anomalies.

Chapter 6 — Password Attacks and Authentication

Most breaches still start with credentials. Understand brute force, dictionary attacks, credential stuffing, password spraying, and rainbow tables. Tools: hashcat and john the ripper for offline cracking, hydra for online (in a lab).

Defence

Long passphrases, bcrypt/argon2 hashing with per-user salt, rate limiting, MFA (preferably WebAuthn / passkeys), and breach-password rejection.

Chapter 7 — Wireless and Social Engineering

Wireless

WPA2 handshake capture with airodump-ng and offline cracking; WPA3 mitigates this with SAE. Rogue access points and evil-twin attacks exploit auto-connect behaviour.

Social engineering

Phishing remains the #1 initial access vector. Defence is technical (DMARC/DKIM/SPF, attachment sandboxing, hardware MFA) plus human (training and a blame-free reporting culture).

Chapter 8 — Reporting, Career, and Responsible Disclosure

A bug bounty or pentest report should contain: title, severity (CVSS), affected asset, step-by-step reproduction, proof-of-concept, business impact, and remediation.

Certifications worth pursuing

CompTIA Security+ → eJPT → PNPT or OSCP → OSWE/OSEP for specialisation.

Responsible disclosure

If you find a vulnerability outside a bounty programme, report it privately to the vendor, give them reasonable time (commonly 90 days) to fix, and only then consider public disclosure.

Closing

Use these skills to defend, never to harm. Stay curious, stay legal. — S. Hareedh, Matrix Minds

Thank you for reading.

This eBook was drafted by **S. Hareedh**, Founder of Matrix Minds. If it helped you, share it with one friend who is starting out. For feedback, write to **matrixmindsha@gmail.com**.